NovaBridge Financial Services Pvt. Ltd.

Third-Party Risk Policy

Document owner: <Your name>, GRC Analyst

Effective Date: 10-04-2026

Next Review Date: 1 year from Effective date or upon significant changes.

Approval Authority: Priya Nair, Head of GRC

Version Control:

Version no.	Creation/Changes made	Approved By
1.0	Third- party Risk Policy creation	Head of GRC

Purpose & Scope

The purpose and scope of this Third-Party Risk Management Policy are to establish a comprehensive framework for identifying, assessing, monitoring, and mitigating risks arising from relationships with third-party vendors, service providers, and external partners that access, process, store, or transmit organizational data or interact with organizational systems. This policy applies to all stakeholders, including customers, employees, contractors, and other interested parties whose information may be shared with or impacted by third-party services. It covers the entire third-party lifecycle—from onboarding and due diligence to ongoing monitoring and termination—and includes all types of data, such as personal, financial, confidential, and operational information. The policy is designed to ensure compliance with applicable legal, regulatory, and contractual obligations while safeguarding data privacy, maintaining information security, and minimizing operational, financial, and reputational risks across all business units and geographies.

Definitions

- **Vendors / Service Providers / External Partners**: Organizations or individuals contracted to deliver goods or services, including IT services, cloud hosting, outsourcing, consulting, or payment processing.
- **Third-Party Risk Management (TPRM)**: A structured process to identify, assess, monitor, and mitigate risks associated with engaging third parties.
- **Organizational Data**: Any data owned, processed, or managed by the organization, including business, operational, financial, and personal data.
- **Stakeholders**: Individuals or groups with an interest in or affected by the organization's activities, including customers, employees, regulators, and partners.
- **Third-Party Lifecycle**: The end-to-end stages of managing third-party relationships, including onboarding, due diligence, risk assessment, contracting, ongoing monitoring, and termination.
- **Due Diligence**: The process of evaluating a third party's capability, reliability, security posture, and compliance before engagement.
- **Ongoing Monitoring**: Continuous oversight of third-party performance, compliance, and risk exposure throughout the engagement.
- **Termination**: The formal process of ending a third-party relationship, including secure data return or disposal and access revocation.
- **Personal Data**: Any information that identifies or can be used to identify an individual, directly or indirectly.
- **Financial Data**: Information related to financial transactions, accounts, payments, or financial status.
- **Confidential Data**: Sensitive information that is restricted to authorized individuals and protected from unauthorized disclosure.
- **Operational Data**: Information related to the organization's day-to-day business activities and processes.

- **Legal Obligations**: Requirements imposed by laws and regulations that the organization must comply with.
- **Regulatory Obligations**: Rules and guidelines set by regulatory authorities applicable to the organization's industry or operations.
- **Contractual Obligations**: Commitments and responsibilities defined in agreements between the organization and third parties.
- **Operational Risk**: The risk of loss resulting from inadequate or failed internal processes, systems, or external events.
- **Financial Risk**: The risk of financial loss due to third-party failures or disruptions.
- **Reputational Risk**: The risk of damage to the organization's reputation due to third-party actions or failures.

Roles and Responsibilities

- **Board of Directors / Senior Management**
  - Provide strategic oversight for third-party risk management practices.
  - Approve the Third-Party Risk Management Policy and ensure alignment with organizational objectives.
  - Ensure adequate resources are allocated for effective implementation of TPRM.
  - Review high-risk third-party relationships and associated risk exposure.

- **Governance, Risk & Compliance (GRC) Team**
  - Develop, implement, and maintain the TPRM framework, policies, and procedures.
  - Conduct third-party risk assessments and assign risk ratings.
  - Maintain the centralized third-party inventory/register.
  - Ensure compliance with regulatory, legal, and internal security requirements.
  - Coordinate with stakeholders for risk treatment and remediation tracking.
  - Perform periodic reviews and reassessments of third-party risks.

- **Information Security / IT Security Team**
  - Perform technical security assessments of third parties (e.g., infrastructure, application, network security).
  - Review security controls, certifications (e.g., ISO 27001), and compliance posture.
  - Identify vulnerabilities and recommend mitigation measures.
  - Support incident response involving third parties.

- **Vendor Management Team**
  - Manage vendor selection, onboarding, and contracting processes.
  - Ensure that all contracts include necessary security, privacy, and compliance clauses.

    - Maintain documentation related to vendor agreements and renewals.
    - Coordinate with GRC and legal teams during vendor evaluation.

- **Third Parties (Vendors / Service Providers)**
    - Comply with all contractual, security, and regulatory requirements.
    - Implement appropriate security controls to protect organizational data.
    - Promptly report security incidents, breaches, or compliance issues.
    - Participate in risk assessments, audits, and monitoring activities.

Vendor Risk Tiering

Third parties shall be classified based on the following factors:

- **Data Sensitivity**: Type of data accessed, processed, or stored (e.g., personal, financial, confidential)
- **System Access**: Level of access to internal systems, networks, or infrastructure
- **Business Criticality**: Impact on business operations if the vendor fails
- **Regulatory Impact**: Involvement in regulated processes (e.g., financial transactions, KYC)
- **Service Dependency**: Degree of reliance on the vendor for core services

<u>Risk Classification Levels:</u>

- **Critical Risk:**
    - Vendors that:
        - Have access to **highly sensitive and regulated data** (e.g., full customer financial data, Aadhaar, PAN)
        - Have **privileged or deep integration access to core infrastructure**
        - Are essential for **core business operations** (failure = business stops)
        - Are subject to **strict regulatory oversight**
    - Requirements:
        - Comprehensive due diligence (business + security + technical)
        - Detailed security assessment
        - Mandatory certifications (ISO 27001 / SOC 2 / etc.)
        - Senior management approval
        - Continuous monitoring (quarterly or ongoing)
        - Annual or more frequent reassessment
        - Strict contractual controls (audit rights, breach SLAs)
- **High Risk:**
    - Vendors that:
        - Have access to **sensitive data (but not full critical datasets)**
        - Have **limited or controlled system access**
        - Support **important business operations** but not core infrastructure

    - **Requirements:**
        - Detailed due diligence
        - Security questionnaire + selective technical validation
        - GRC and business approval
        - Periodic monitoring
        - Annual (or more frequent) reassessment
- **Medium Risk:**
    - Vendors that:
        - Have **limited access to non-sensitive or internal data**
        - Support **important but non-critical functions**
        - Have **indirect system interaction**
    - **Requirements:**
        - Standard risk assessment
        - Security questionnaire
        - Periodic monitoring
        - Reassessment every 1–2 years
- **Low risk:**
    - Vendors that:
        - Have **no access to sensitive data**
        - Do not interact with critical systems
        - Provide **non-critical services**
    - **Requirements:**
        - Basic due diligence
        - Minimal assessment
        - Monitoring as needed

<u>System Access Levels:</u>

- **Level 1 (Low): Minimal Access**
    - Public / Low Impact
    - Third party provides services with little or no user data
    - No PII or anonymized data

- **Level 2 (Medium): Limited data access**
    - Basic Processing
    - Handles basic PII for operational purposes
    - Email, phone, basic profile data

- **Level 3 (High): Sensitive Data Access**
    - High-Risk Processing
    - Processes sensitive PII (identity, financial, biometric)
    - ID docs, biometrics, financial data

- **Level 4 (Critical): Privileged/Full System Access**
    - Deep Integration
    - Direct or indirect access to internal systems or large datasets
    - Broad or full user data

Risk Tiering Process:

- Vendor Owner provides initial classification based on business context
- GRC team validates and finalizes the risk tier
- Information Security team supports classification where technical risk is involved
- Final classification is documented in the Vendor Inventory Register

Due Diligence Requirements

- The purpose of due diligence is to evaluate the capability, security posture, compliance status, and overall risk associated with a third party prior to engagement, ensuring that the organization does not enter into relationships that expose it to unacceptable risk.
- Due diligence shall be performed for all third parties prior to onboarding and shall be proportionate to the vendor's risk classification (High, Medium, Low).

- **Due Diligence Process:**
    - **Business & Operational Assessment:**
        - Evaluate vendor's business background, reputation, and financial stability
        - Review years of operation, market presence, and client references
        - Assess ability to deliver services as per business requirements

    - **Security and Privacy Assessment:**
        - Review vendor's information security policies and procedures
        - Assess implementation of key security controls
        - Evaluate data protection and privacy practices

    - **Compliance & Regulatory Assessment:**
        - Verify compliance with applicable laws and regulations
        - Review certifications such as:
            - ISO 27001
            - SOC 2, etc.
        - Ensure alignment with industry-specific regulatory requirements (e.g., financial regulations)

    - **Financial & Legal Assessment**
        - Evaluate financial health and stability of the vendor
        - Review legal history, disputes, or regulatory penalties
        - Validate licensing and legal authorization to operate

- **Technical Assessment (if applicable)**
    - Conduct technical security review for high-risk vendors
    - Assess:
        - Network architecture
        - Application security
        - Cloud security configurations, etc.
    - Identify vulnerabilities and control gaps

- **<u>Documentation & Record Keeping</u>**
    - All due diligence findings shall be documented and retained
    - Records shall include:
        - Assessment reports
        - Questionnaires
        - Certifications and evidence reviewed
    - Documentation shall be maintained in the centralized vendor repository

- **<u>Approval & Onboarding</u>**
    - Vendors shall only be onboarded after:
        - Completion of due diligence
        - Risk assessment and classification
        - Approval from relevant stakeholders

Policy Review Cycle

- This Third-Party Risk Management Policy shall be reviewed at least **annually** or upon significant changes to the organization's business operations, regulatory requirements, or risk environment. Significant changes include: **regulatory amendments, major breach, or new high-risk vendor onboarding**
- The review shall be conducted by the GRC team in coordination with relevant stakeholders to ensure continued effectiveness, alignment with industry standards, and compliance with applicable legal and regulatory obligations.
- Any updates or revisions to this policy must be formally approved by Senior Management prior to implementation.